

NIST 800-171 Master Blueprint

Candidate Focus: Technical Audit & Risk Architecture

"I identified **61% of risks** that required enterprise-level budgets I didn't have. Instead of ignoring them, I architected **compensating controls** using Apple-native security features to meet the **intent** of the NIST framework."

I. The Senior GRC Philosophy

A Senior Analyst distinguishes themselves by moving beyond technical scripts to **Business Risk Management**. This project demonstrates the ability to maintain a high security posture in the absence of million-dollar enterprise software budgets.

The Enterprise Infrastructure Gap:
Standard enterprise compliance often relies on \$250k+ Identity Providers (Okta/Azure), \$500k+ SIEMs (Splunk), and \$1M+ physical security infrastructure. In a lab environment, these resources are unavailable. My methodology focuses on **Compensating Controls**—alternative measures that provide equivalent protection levels to the primary requirement.

II. Risk-Adjusted Audit Table (POA&M)

CONTROL	ENTERPRISE REQUIREMENT	THE INFRASTRUCTURE GAP	COMPENSATING CONTROL
3.1.1	Centralized Identity (Okta)	No Cloud Identity Provider	Hardware-Locked Identity: Binding local login to the Mac's Secure Enclave & TouchID.
3.3.1	Enterprise SIEM (Splunk)	Local logs are volatile	Immutable Cloud Forwarding: Zsh-automated log streaming to encrypted cloud storage.

CONTROL	ENTERPRISE REQUIREMENT	THE INFRASTRUCTURE GAP	COMPENSATING CONTROL
3.5.3	Hardware Token MFA	Cost/Shipping logistics	FIDO2 Passkeys: Native biometric hardware-bound keys tethered to the physical Mac.
3.10.1	Physical Badge Access	Remote-First/Home Office	Encryption as Perimeter: FileVault 2 + Firmware Passwords + 15-min Auto-Logout.
3.14.6	24/7 SOC Monitoring	No Human Security Team	Self-Healing Automation: Jamf Profiles that auto-revert unauthorized configuration drift.

III. Enterprise Scaling & Change Management

Transitioning from a **Task-based** mindset (scripts) to a **State-based** mindset (profiles) ensures system integrity and creates a professional audit trail.

Step 1: Configuration Persistence

Utilizing Jamf Pro to deploy .mobileconfig profiles ensures that technical controls are not just implemented, but **enforced**, preventing configuration drift by unauthorized users.

Step 2: Senior-Level Pull Request Description

Title: NIST 3.1.20 Implementation: Firewall Persistence & Stealth Mode

PR Description:

This PR remediates NIST 800-171 Control 3.1.20.

Technical Action: Implemented stealth mode and blocked unauthorized inbound connections via shell automation.

Critical Thinking: To address the intent of **Baseline Integrity**, I transitioned this logic into a **Jamf Configuration Profile**. This prevents **Configuration Drift** by ensuring the MDM automatically re-enforces the locked state if a user attempts to revert security settings.

Result: Successfully operationalized security without sacrificing business agility.

IV. Final Portfolio Audit Readiness

- ✅ **Folder 01 (Baseline):** Documented 7.38% initial state for evidence-based gap analysis.
- ✅ **Folder 02 (Sandbox):** Validated Zsh remediation scripts for rapid technical deployment.
- ✅ **Folder 03 (Enterprise):** Scaled controls via Jamf Profiles for persistent state enforcement.
- ✅ **Folder 04 (Governance):** Final POA&M managing 61.74% residual risk with professional maturity.